

Marco integrativo GQM + PRAGMATIC para indicadores CRA

Versión: 1.0

Ámbito: indicadores nacionales/territoriales de preparación CRA (Cyber Resilience Act)

1. Propósito del marco

Este documento articula un **marco integrativo** que conecta:

- Objetivos estratégicos nacionales vinculados al CRA.
- Preguntas de evaluación (nivel país, sector y organización).
- Métricas técnicas, operativas y económicas.

La espina dorsal es GQM (Goal–Question–Metric), condimentada con el aderezo PRAGMATIC (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable), aplicado a cada métrica para asegurarnos de que no coleccionamos números por deporte.

2. Recordatorio del enfoque GQM

- Goal (Objetivo): qué queremos lograr o comprender, en términos alineados con el CRA y las estrategias nacionales de ciberseguridad.
- Question (Pregunta): cuestiones específicas cuya respuesta nos indica si el objetivo se está alcanzando.
- Metric (Métrica): datos cuantitativos o semicuantitativos que permiten responder a las preguntas.

En este marco, cada indicador CRA propuesto se expresa como un “M” al final de una cadena G–Q–M explícita.

3. Recordatorio del enfoque PRAGMATIC

Cada métrica se valora con los nueve criterios PRAGMATIC:

1. Predictivo: ¿ayuda a anticipar resultados futuros relevantes?
2. Relevante: ¿está claramente vinculada a objetivos CRA/nacionales?
3. Accionable: ¿puede activar decisiones concretas?
4. Genuino: ¿mide lo que dice medir (validez)?
5. Significativo: ¿tiene peso suficiente como para importar?
6. Preciso: ¿puede medirse con exactitud adecuada?
7. Oportuno: ¿puede obtenerse con la frecuencia necesaria?
8. Independiente: ¿evita sesgos excesivos de percepción/intereses?
9. Rentable: ¿su coste de obtención es razonable frente a su valor?

Calificamos cada métrica en una escala 1–5 (baja–alta), con una breve justificación narrativa.

4. Objetivos GQM top–down para CRA (nivel país)

Se adoptan cinco grandes objetivos (G1–G5) que agrupan los indicadores del informe CRA:

- **G1 – Gobernanza y marco institucional:**
Asegurar que el país dispone de estructuras de gobernanza, coordinación y supervisión adecuadas para implementar el CRA de forma eficaz.
- **G2 – Cobertura y conformidad de productos:**
Aumentar la proporción de productos con elementos digitales en el mercado nacional que cumplen los requisitos CRA o estándares equivalentes.
- **G3 – Gestión de vulnerabilidades e incidentes:**
Reducir la exposición del país a vulnerabilidades explotadas e incidentes graves derivados de productos digitales, mejorando tiempos de detección y respuesta.
- **G4 – Resiliencia económica y de mercado:**
Minimizar el impacto económico de incidentes relacionados con productos digitales y mejorar la sostenibilidad financiera de la ciberresiliencia.
- **G5 – Capacidades, cultura y métricas:**
Desarrollar capacidades técnicas, humanas y de medición que permitan una mejora continua y basada en datos.

G1 – Gobernanza y marco institucional:

Asegurar que el país dispone de estructuras de gobernanza, coordinación y supervisión adecuadas para implementar el CRA de forma eficaz.

G2 – Cobertura y conformidad de productos:

Aumentar la proporción de productos con elementos digitales en el mercado nacional que cumplen los requisitos CRA o estándares equivalentes.

G3 – Gestión de vulnerabilidades e incidentes:

Reducir la exposición del país a vulnerabilidades explotadas e incidentes graves derivados de productos digitales, mejorando tiempos de detección y respuesta.

G4 – Resiliencia económica y de mercado:

Minimizar el impacto económico de incidentes relacionados con productos digitales y mejorar la sostenibilidad financiera de la ciberresiliencia.

G5 – Capacidades, cultura y métricas:

Desarrollar capacidades técnicas, humanas y de medición que permitan una mejora continua y basada en datos.

Cada indicador del informe CRA se encaja en alguno de estos objetivos (a veces en varios, pero se asigna un “hogar” principal para evitar esquizofrenias metodológicas).

5. GQM aplicado a los indicadores CRA

A continuación se presentan los GQM por familia de indicadores (resumen conceptual; la matriz PRAGMATIC se detalla en un archivo separado).

5.1 G2 – Cobertura y conformidad de productos

Indicador 1 – Proporción de productos con elementos digitales en el mercado nacional que declaran cumplimiento CRA (por número de modelos y cuota de mercado).

- G: Incrementar la penetración de productos CRA-conformes en el parque tecnológico nacional.
- Q1: ¿Qué porcentaje de productos disponibles en el mercado nacional se declara conforme con CRA?
- Q2: ¿Qué porcentaje del parque instalado efectivo (por cuota de mercado) corresponde a productos conformes?
- M1.1: N° de modelos de producto en mercado con declaración CRA / N° total de modelos de producto relevantes.
- M1.2: Cuota de mercado (unidades o facturación) de productos declarados CRA / cuota total.

Indicador 2 – N° de fabricantes sujetos a CRA con procesos de gestión de vulnerabilidades certificados o auditados.

- G: Garantizar que los fabricantes relevantes operan procesos maduros de gestión de vulnerabilidades.
- Q1: ¿Cuántos fabricantes con presencia significativa en el país han sometido sus procesos a certificación o auditoría independiente?
- Q2: ¿Qué cobertura representa respecto al volumen de productos en el mercado?
- M2.1: N° de fabricantes con procesos certificados/auditados / N° total de fabricantes identificados.
- M2.2: Porcentaje de productos en el mercado procedentes de fabricantes con procesos certificados.

Indicador 3 – N° de certificaciones EUCC emitidas para productos relevantes y distribución por nivel de garantía.

- G: Aumentar el uso de esquemas de certificación armonizados para productos críticos.
- Q1: ¿Cuántas certificaciones EUCC (u otros esquemas CRA-relevantes) se han emitido en el país?
- Q2: ¿En qué niveles de garantía se concentran (básico, sustancial, alto)?
- M3.1: N° de certificados EUCC vigentes por nivel de garantía.
- M3.2: Distribución porcentual por nivel de garantía para sectores clave.

Indicador 4 – Porcentaje de entidades críticas que utilizan sólo productos CRA-conformes o certificados en segmentos sensibles.

- G: Reducir la exposición de infraestructuras críticas a productos inseguros o no conformes.
- Q1: ¿Qué parte del parque tecnológico crítico (OT, redes, 5G, etc.) está cubierto por productos CRA-conformes o certificados?
- M4.1: % de activos críticos con productos CRA-conformes / total de activos críticos en inventario.

5.2 G3 – Gestión de vulnerabilidades e incidentes

Indicador 5 – Tiempo medio hasta parche (TTP) para vulnerabilidades críticas en productos sujetos a CRA.

- G: Minimizar el tiempo de exposición a vulnerabilidades críticas en productos en uso.
- Q1: ¿Cuál es el TTP medio para vulnerabilidades críticas en productos CRA en el país?
- Q2: ¿Existen diferencias significativas según fabricante, sector o criticidad?
- M5.1: Promedio de días entre identificación de vulnerabilidad crítica y disponibilidad de parche, por producto/fabricante.
- M5.2: Distribución (mediana, percentiles 90) del TTP por segmento.

Indicador 6 – Proporción de vulnerabilidades explotadas activamente con más de un año de antigüedad en el parque nacional (“aging vulns”).

- G: Reducir el stock de vulnerabilidades críticas no resueltas que siguen explotándose.
- Q1: ¿Qué porcentaje de vulnerabilidades explotadas activamente tiene más de X días/meses de antigüedad?
- M6.1: N° de vulnerabilidades explotadas > 12 meses / N° total de vulnerabilidades explotadas en el periodo.
- M6.2: Media de antigüedad (días) de vulnerabilidades explotadas.

Indicador 7 – Porcentaje de instalaciones que aplican parches críticos en un plazo objetivo (por ejemplo, 30 días).

- G: Aumentar la tasa de adopción oportuna de parches críticos por parte de los usuarios.
- Q1: ¿Qué proporción de instalaciones aplica parches críticos dentro del plazo definido?
- M7.1: N° de instalaciones parcheadas ≤ 30 días / N° total de instalaciones afectadas.

Indicador 8 – N° de vulnerabilidades notificadas vía plataforma CRA y distribución por criticidad y tiempo de mitigación.

- G: Mejorar la transparencia y la gestión coordinada de vulnerabilidades a nivel europeo/nacional.
- Q1: ¿Cuántas vulnerabilidades se notifican por periodo y con qué criticidad?
- Q2: ¿Cuánto tiempo transcurre hasta su mitigación efectiva?
- M8.1: N° de vulnerabilidades notificadas por criticidad (baja-media-alta-crítica).
- M8.2: Tiempo medio de mitigación (descubrimiento – parche – despliegue).

Indicador 9 – Nº de incidentes significativos asociados a productos CRA por año, sector e impacto.

- G: Monitorizar y reducir la incidencia de eventos graves ligados a productos digitales.
- Q1: ¿Cuántos incidentes significativos se registran y con qué características?
- M9.1: Nº de incidentes significativos por sector/año.
- M9.2: Clasificación de impacto (servicio, datos, daños físicos, etc.).

Indicador 10 – % de incidentes notificados dentro de plazos CRA y calidad del reporte.

- G: Asegurar el cumplimiento de los plazos de notificación y la utilidad de la información proporcionada.
- Q1: ¿Qué porcentaje de incidentes se notifica en plazo?
- Q2: ¿Cuántos informes son completos y útiles para la gestión coordinada?
- M10.1: Nº incidentes notificados en plazo / Nº total incidentes significativos.
- M10.2: % de informes que cumplen criterios de completitud/calidad definidos.

Indicador 11 – MTDD y MTTC/MTTR para incidentes vinculados a productos CRA.

- G: Reducir los tiempos de detección y contención de incidentes críticos.
- Q1: ¿Cuál es el MTDD/MTTR promedio en sectores esenciales?
- M11.1: MTDD medio (horas/días).
- M11.2: MTTR medio (horas/días).

5.3 G4 – Resiliencia económica y de mercado

Indicador 12 – Porcentaje de organizaciones con ciberseguro o certificaciones relevantes.

- G: Fomentar la transferencia madura de riesgo y la adopción de prácticas verificadas.
- Q1: ¿Qué porcentaje de organizaciones dispone de ciberseguro o certificaciones de seguridad?
- M12.1: % organizaciones con ciberseguro.
- M12.2: % organizaciones con certificaciones (ISO 27001, EUCC, etc.).

Indicador 13 – Estimación de pérdidas económicas directas e indirectas por incidentes CRA como % del PIB o valor añadido sectorial.

- G: Cuantificar el impacto macroeconómico de la falta de resiliencia en productos digitales.
- Q1: ¿Cuál es el coste económico agregado anual de incidentes ligados a productos CRA?
- M13.1: Pérdidas estimadas / PIB nacional.
- M13.2: Pérdidas estimadas / VAB sectorial.

Indicador 14 – Gasto público/privado en ciberseguridad como % del presupuesto TIC, y parte atribuible a CRA.

- G: Evaluar la suficiencia y orientación del esfuerzo inversor en ciberresiliencia.
- Q1: ¿Qué porcentaje de presupuesto TIC se invierte en ciberseguridad y CRA?
- M14.1: Gasto en ciberseguridad / Gasto TIC total.
- M14.2: Gasto CRA estimado / Gasto ciberseguridad.

Indicador 15 – Nivel de concentración de proveedores críticos y dependencia de productos no conformes o extracomunitarios sin certificación.

- G: Reducir riesgos de concentración y dependencia de productos opacos o no conformes.
- Q1: ¿Cuál es el grado de concentración de proveedores de productos críticos?
- Q2: ¿Qué peso tienen productos no conformes o no certificados?
- M15.1: Índice de Herfindahl-Hirschman (HHI) de proveedores críticos.
- M15.2: % de activos críticos que dependen de productos sin certificación reconocida.

5.4 G1 y G5 – Gobernanza, capacidades y métricas

Indicador 16 – Capacidad de las autoridades de vigilancia de mercado (inspecciones, recursos, sanciones).

- G: Asegurar que las autoridades disponen de medios suficientes para supervisar el CRA.
- Q1: ¿Cuántas inspecciones y evaluaciones se realizan?
- Q2: ¿Con qué recursos y tiempos de tramitación?
- M16.1: N° de inspecciones/año y recursos por inspector.
- M16.2: Tiempo medio de tramitación de expedientes.

Indicador 17 – Avance en la implementación de la Estrategia Nacional de Ciberseguridad y planes INCIBE/CNCS.

- G: Alinear la implementación del CRA con las estrategias y planes nacionales.
- Q1: ¿Qué porcentaje de acciones CRA-relevantes está completado?
- M17.1: % de hitos CRA-relevantes completados / plan total.

Indicador 18 – Tamaño y cualificación de la fuerza laboral en ciberseguridad, incluyendo perfiles de desarrollo seguro y análisis de vulnerabilidades.

- G: Aumentar el capital humano especializado necesario para aplicar el CRA.
- Q1: ¿Cuál es el volumen y la evolución de profesionales en roles CRA-relevantes?
- M18.1: N° de profesionales en perfiles de ciberseguridad y desarrollo seguro por 100.000 habitantes.
- M18.2: % de vacantes no cubiertas en estos perfiles.

Indicador 19 – Nivel de satisfacción de Estados/autoridades con el apoyo de ENISA y eficacia del marco CRA.

- G: Mejorar la coordinación y apoyo europeo para la implementación CRA.
- Q1: ¿Cómo valoran las autoridades nacionales el soporte recibido y la eficacia del marco?
- M19.1: Índice de satisfacción (encuesta a autoridades) 0–100.

Indicador 20 – Existencia y uso de cuadros de mando CRA en organizaciones clave.

- G: Fomentar la toma de decisiones basada en datos sobre CRA en organizaciones estratégicas.
- Q1: ¿Qué proporción de organizaciones estratégicas dispone de dashboards CRA?
- M20.1: % de organizaciones críticas con cuadro de mando CRA operativo.

6. Integración GQM en la práctica

Este marco permite:

- Trazar cada dato técnico (M) a las preguntas que responde (Q) y al objetivo nacional que contribuye a alcanzar (G).
- Ver dónde faltan métricas para ciertas preguntas, y dónde sobran métricas que no responden a ningún objetivo.
- Evaluar, con PRAGMATIC, la calidad de cada métrica antes de invertir esfuerzos significativos en su recogida.

La Matriz PRAGMATIC completa —con valores 1–5 por indicador— se encuentra en el archivo `CRA_GQM_PRAGMATIC_MatrizEvaluacionCompleta.md`.